PROYECTO 2

Investigación Comparativa: Plataformas de Simulación de Phishing

6 DE MARZO DE 2026
UPSLP
CNO V Seguridad Informática

Introducción

El **phishing** sigue consolidándose como el vector de ataque principal a nivel global, responsable de más del 80% de los incidentes de brecha de datos documentados. En el panorama actual de la ciberseguridad, el Factor Humano sigue siendo el eslabón más vulnerable y, a la vez, la primera línea de defensa. La simulación de phishing no busca "engañar" al empleado, sino entrenar su reflejo cognitivo para detectar anomalías.

El objetivo central de esta investigación es analizar exhaustivamente las herramientas tecnológicas que permiten a las organizaciones medir, cuantificar y mitigar este riesgo humano mediante el entrenamiento continuo y la concientización (Security Awareness Training - SAT).

A través de la simulación controlada, el propósito es facilitar la transición de un modelo de seguridad perimetral tradicional y punitivo hacia la consolidación de una Cultura de Seguridad Activa (Human Firewall). Esto implica capacitar a los empleados para que actúen como sensores humanos de detección de amenazas en tiempo real.

Fichas Descriptivas de las Plataformas

1.1 KnowBe4 (Security Awareness Training)

- **Perfil:** Líder indiscutible del mercado por volumen de contenido. Fundada con el apoyo de Kevin Mitnick.
- **Fortaleza:** Su biblioteca de contenido es la más vasta del mundo. Incluye el **Virtual Risk Officer (VRO)** que asigna una puntuación de riesgo individual a cada usuario basada en su comportamiento.
- **Innovación:** Herramientas como *AITP (Artificial Intelligence Driven Agent)* que personaliza las simulaciones según el nivel de habilidad del usuario.

1.2 Proofpoint (Security Awareness Training - PSAT)

- **Perfil:** Enfoque corporativo de alto nivel, integrado con su ecosistema de protección de correo (Gateway).
- **Fortaleza:** Utiliza inteligencia de amenazas real. Si un usuario es identificado como una **VAP (Very Attacked Person)** por el sistema de protección, la plataforma le asigna automáticamente módulos de refuerzo específicos.
- **Enfoque:** Muy centrado en la reducción del riesgo técnico mediante datos operativos.

1.3 Hoxhunt

- **Perfil:** Plataforma finlandesa que revoluciona el entrenamiento mediante la **gamificación extrema**.

- **Fortaleza:** Automatización total. No requiere que un administrador diseñe campañas; la IA envía correos personalizados en momentos óptimos.
- **Diferenciador:** Premia el "reporte" por encima de la "detección". Los usuarios ganan puntos y escalan niveles al enviar correos sospechosos al buzón de seguridad.

1.4 Cofense (Anteriormente PhishMe)

- **Perfil:** Orientado a la respuesta de incidentes más que solo al entrenamiento.
- **Fortaleza:** Su ecosistema **Cofense Triage** permite que, cuando un empleado reporta un correo, el equipo de SOC pueda analizarlo y eliminarlo de todos los buzones de la empresa en segundos.
- **Enfoque:** Construcción de una red de sensores humanos para la detección temprana.

1.5 Phished

- **Perfil:** Plataforma 100% automatizada basada en algoritmos de aprendizaje profundo.
- **Fortaleza:** Elimina la carga administrativa. Genera simulaciones hiper-realistas basadas en el contexto del usuario (LinkedIn, cargo, herramientas que usa).
- **Valor:** Ideal para organizaciones con equipos de TI reducidos que necesitan resultados de alta calidad sin gestión manual.

1.6 Ninjio

- **Perfil:** Enfoque único en la **narrativa visual** (Storytelling).
- **Fortaleza:** Produce episodios de animación tipo "Hollywood" de 3 minutos, basados en brechas de seguridad reales que ocurrieron esa semana.
- **Impacto:** Logra una alta retención emocional al convertir el aprendizaje en una experiencia de entretenimiento breve pero poderosa.

1.7 Mimecast (Awareness Training)

- **Perfil:** Integración nativa con su solución de seguridad de correo perimetral.
- **Fortaleza:** Utiliza el humor y videos cortos para combatir la "fatiga de seguridad".
- **Sinergia:** Los datos de las simulaciones alimentan directamente las políticas de filtrado del correo real de la empresa.

1.8 Infosec IQ

- **Perfil:** Enfoque pedagógico profundo y cumplimiento (Compliance).

- **Fortaleza:** Ofrece planes de aprendizaje alineados con marcos como NIST, ISO 27001 y GDPR.
- **Análisis:** Sus dashboards de reporte son extremadamente granulares, permitiendo ver el progreso por departamentos o geolocalización.

Tabla Técnica Comparativa

Para evaluar estas herramientas, definimos los siguientes criterios: **IA & Automatización**, **Capacidad de Reporte (SOC)**, **Gamificación**, **Biblioteca de Contenidos** y **Facilidad de Despliegue**.

Plataforma	IA & Automatización	Integración SOC	Gamificación	Calidad de Contenido	Modelo de Licenciamiento
KnowBe4	Alta	Media	Media	Excelente	Por usuario / anual
Proofpoint	Media	Alta (Nativa)	Baja	Alta	Basado en módulos
Hoxhunt	Muy Alta	Media	Muy Alta	Dinámica	Por usuario activo
Cofense	Media	Muy Alta	Baja	Profesional	Corporativo
Phished	Muy Alta	Media	Media	Personalizada	SaaS suscripción
Ninjio	Baja	Baja	Alta	Premium (Video)	Basado en episodios
Mimecast	Media	Alta	Media	Alta	Paquete de seguridad
Infosec IQ	Media	Media	Baja	Educativa	Por usuario

Criterios de Análisis y Enfoque Ético

La implementación de estas plataformas no debe ser vista como una "trampa" para los empleados. Para cumplir con los estándares éticos de un profesional de TI, se deben seguir estos principios:

A. El Momento Educativo (The Teachable Moment)

Cuando un usuario cae en una simulación, no debe recibir un mensaje de error o una reprimenda. Debe ser redirigido a una página de aterrizaje (Landing Page) que explique de forma positiva:

1. Qué señales del correo eran sospechosas (ej. remitente mal escrito, sentido de urgencia).
2. Qué debió haber hecho (ej. reportar el correo).
3. Un micro-módulo de 30 segundos de refuerzo.

B. Política de No Punición

Éticamente, las fallas en simulaciones **no deben ser causa de despido o sanciones laborales**. Los datos deben usarse para:

- Asignar más entrenamiento.
- Reforzar controles técnicos en áreas de alto riesgo.
- Identificar líderes de seguridad dentro de la organización.

C. Transparencia y Consentimiento

Aunque las simulaciones son sorpresa, el departamento de Recursos Humanos y el Sindicato (si existe) deben estar informados. Es una buena práctica ética anunciar que la empresa iniciará un programa de "Cultura de Seguridad" meses antes de la primera simulación.

D. Respeto a la Privacidad (GDPR / LFPDPPP)

Los datos recolectados (quién dio clic, a qué hora, desde qué dispositivo) deben ser protegidos con el mismo rigor que la información confidencial de la empresa, evitando la exposición pública de los "falladores" recurrentes.

Metodología de Implementación Sugerida

Para que el proyecto PR02 sea integral, la metodología debe seguir el ciclo de mejora continua:

1. **Línea Base (Baseline):** Una simulación inicial sin entrenamiento previo para conocer el estado real de la empresa.
2. **Entrenamiento Proactivo:** Despliegue de contenidos educativos.
3. **Simulaciones Iterativas:** Aumentar gradualmente la dificultad de los ataques (de un correo mal escrito a uno que simula ser de la Intranet corporativa).
4. **Medición de Resiliencia:** No solo medir quién da clic, sino cuántas personas reportan el ataque. La métrica real de éxito es el **Ratio de Reporte** (R_r) definido por:

$$R_r = \frac{Usuarios\ que\ Reportan}{Usuarios\ que\ dan\ Clic}$$

Si R_r> 1, la cultura de seguridad está madurando positivamente.

Conclusión

La investigación de estas plataformas demuestra que la simulación de phishing ha evolucionado de ser una simple prueba técnica a convertirse en una herramienta de Ingeniería del Comportamiento. No basta con desplegar tecnología perimetral (firewalls o gateways de correo) si el eslabón humano permanece vulnerable a tácticas de persuasión psicológica.

Las soluciones analizadas como KnowBe4 o Hoxhunt marcan una pauta clara: la efectividad no reside en la dificultad del engaño, sino en la capacidad de generar un "hábito de reporte". Al integrar IA para personalizar ataques, las organizaciones pueden anticiparse a las amenazas reales, transformando a cada empleado en un sensor activo que nutre al SOC en tiempo real.

En última instancia, el éxito de un programa de simulación de phishing no se mide por cuántos usuarios hacen clic, sino por la velocidad con la que la amenaza es identificada, reportada y neutralizada por la comunidad interna, logrando así una verdadera Resiliencia Cognitiva ante el panorama de ciberamenazas modernas.

Bibliografía

- *Cofense. (2023). Annual State of Phishing Report: Crowdsourced Intelligence and Email Security Trends.* cofense.com
- *Gartner, Inc. (2024). Magic Quadrant for Security Awareness Computer-Based Training. Gartner Reprint.* gartner.com
- *Herzog, P. (2010). Open Source Security Testing Methodology Manual (OSSTMM) (v. 3). Institute for Security and Open Methodologies (ISECOM).* isecom.org
- *Infosec Institute. (2024). Infosec IQ: Phishing Simulation and Security Awareness Training Roadmap.* infosecinstitute.com
- *KnowBe4. (2024). Phishing Industry Benchmarking Report: Analysis by Industry and Organization Size.* knowbe4.com
- *Mimecast Services Limited. (2024). Mimecast Awareness Training: Combating Security Fatigue with Behavior Science.* mimecast.com
- *MITRE Corporation. (2024). MITRE ATT&CK v16: Adversary Tactics and Techniques Based on Real-World Observations.* attack.mitre.org

- *National Institute of Standards and Technology. (2008). Technical Guide to Information Security Testing and Assessment (NIST Special Publication 800-115). U.S. Department of Commerce.* csrc.nist.gov
- *OWASP Foundation. (2024). Web Security Testing Guide (WSTG) (v. 4.2/5.0).* owasp.org/wstg
- *PTES Board. (s. f.). The Penetration Testing Execution Standard.* pentest-standard.org